

YUVA Cybersecurity Internship Comprehensive Report

4-Week End-to-End Security Analysis, Threat Modeling, Incident Response & Strategic Defense Roadmap for AuraGov

Student Name:	Deepika Jaiswal	Target System:	AuraGov Citizen Portal (auragov.service.gov)
Student ID:	2410030120	Program:	YUVA Cybersecurity Internship Program
Assigned Role:	Junior Cyber Security Analyst	Reporting Period:	August 5, 2026 – August 26, 2026

1. Internship Overview & Executive Summary

Over the course of my four-week technical engagement in the **YUVA Cybersecurity Internship Program**, I worked as a **Junior Cyber Security Analyst** assessing and strengthening the security posture of the **AuraGov National Citizen Services Portal** (auragov.service.gov). AuraGov is a high-impact digital public infrastructure hosting over 150 digital services, including national identity verification, land property registries, and welfare benefit disbursements.

My role encompassed the complete cyber defense operational workflow: performing passive footprinting and architecture mapping (Week 1), conducting threat modeling and quantitative risk scoring aligned with MITRE ATT&CK (Week 2), executing a real-time incident response drill under NIST SP 800-61 guidelines (Week 3), and formulating a forward-looking 2026–2030 strategic defense roadmap featuring Post-Quantum Cryptography and Zero-Knowledge Proofs (Week 4).

Summary of Weekly Accomplishments

- Week 1 (Infrastructure Assessment):** Mapped Kubernetes microservices architecture and identified critical BOLA authorization vulnerabilities and JWT validation gaps.
- Week 2 (Threat & Risk Modeling):** Established a 6-tier threat matrix (TR-01 to TR-06), mapped MITRE ATT&CK vectors, and built a 180-day mitigation plan.
- Week 3 (Incident Response Simulation):** Evaluated "Operation Silent Exfil" scenario, achieving a 7-minute MTTD and 15-minute MTTC with zero system downtime.
- Week 4 (Future Trends & Strategy):** Developed the Future Readiness Index (FRI) model and designed a 4-year transition plan toward quantum resilience and Zero Trust.

WEEK 1: Digital Infrastructure Security Assessment

2. System Architecture & Vulnerability Mapping

AuraGov operates on a microservices topology running inside isolated Kubernetes clusters, fronted by Cloudflare edge WAF protection, and backed by an encrypted PostgreSQL cluster (AES-256).

- Presentation Layer:** React-based Single-Page Applications served globally via Content Delivery Networks (CDNs).
- Edge Gateway:** Cloudflare Web Application Firewall filtering DDoS attacks and terminating public TLS 1.3 connections.
- Application Tier:** Spring Boot microservices handling core logic and connecting to state registries (land records, tax databases).
- Data Tier:** PostgreSQL database cluster with AES-256 storage encryption and identity tokenization.

Identified Vulnerabilities Summary

The Week 1 audit revealed four key technical vulnerabilities across public endpoints and integration middleware:

ID	Vulnerability Name	Severity	Target Component	Risk & Potential Impact
VULN-01		CRITICAL	Property Registry API	Authenticated users could modify URL parameter ID values (/api/

ID	Vulnerability Name	Severity	Target Component	Risk & Potential Impact
	Broken Object Level Authorization (BOLA)			v1/property/record?id=XXXX) to download property records of other citizens without authorization.
VULN-02	Weak Cryptographic Token Validation	HIGH	e-Sign Verification Gateway	JSON Web Tokens (JWTs) issued during digital document signing lacked strict issuer validation, risking signature tampering and token forgery.
VULN-03	Insufficient Rate Limiting	MEDIUM	Citizen Login Portal	Login endpoints lacked device fingerprinting and IP rate controls, making authentication endpoints vulnerable to credential stuffing attacks.
VULN-04	Missing Security Headers	LOW	Portal Web Frontends	Omission of strict Content Security Policy (CSP) and X-Frame-Options exposed frontends to clickjacking and cross-site scripting (XSS).

WEEK 2: Threat Landscape Analysis & Strategic Mitigation

3. Threat Actor Profiling & MITRE ATT&CK Alignment

In Week 2, I analyzed threat vectors targeting public sector infrastructure. Due to centralized citizen PII and welfare functions, e-governance platforms attract diverse adversary profiles ranging from nation-states to cybercrime groups.

Threat Actor Class	Primary Motivation	Capability	Target Assets & Attack Vectors
Advanced Persistent Threats (APTs)	Cyber espionage, political disruption	VERY HIGH	Identity registries, API gateways, database clusters.
Organized Cybercrime Syndicates	Financial gain, data extortion, ransomware	HIGH	Welfare disbursement gateways, payment processing APIs.
Hacktivists	Public discrediting, message amplification	MEDIUM	Public web portals, DNS routing, frontend UI.
Malicious / Compromised Insiders	Financial gain, grievances	MEDIUM	Administrative panels, internal log aggregation pipelines.

MITRE ATT&CK Mapping & Quantitative Risk Scoring

Attacks were mapped against MITRE ATT&CK techniques: **T1190** (Exploit Public-Facing Application for BOLA), **T1556** (Modify Authentication Process for JWT forgery), **T1110** (Brute Force on login endpoints), **T1195** (Supply Chain Compromise), and **T1046** (Network Service Discovery in Kubernetes). Risks were evaluated using:

Risk Rating (R) = *Likelihood (1–5) × Impact (1–5)*
| 15–25 Critical | 10–14 High | 5–9 Medium | 1–4 Low

Threat ID	Threat Description	Likelihood	Impact	Score (R)	Priority	Target Mitigation
TR-01	BOLA / Unauthorized Citizen Data Exfiltration	5	5	25	CRITICAL	ABAC Middleware

Threat ID	Threat Description	Likelihood	Impact	Score (R)	Priority	Target Mitigation
TR-02	Middleware JWT Token Forgery / Signature Bypass	4	5	20	CRITICAL	RS256 Validation
TR-03	Internal Lateral Movement across Kubernetes Pods	4	4	16	HIGH	Istio Service Mesh mTLS
TR-04	Automated Credential Stuffing on Login Portals	5	3	15	HIGH	Adaptive WAF Limiting
TR-05	Sensitive Session Metadata Exposure in Error Logs	3	4	12	HIGH	Dynamic Log Masking
TR-06	Frontend Exploitation (XSS / Clickjacking)	3	2	6	MEDIUM	Strict CSP Headers

WEEK 3: Incident Response Simulation ("Operation Silent Exfil")

4. Simulated Incident Execution & Operational Metrics

In Week 3, I participated in a simulated incident response drill ("Operation Silent Exfil") testing AuraGov's readiness against an active BOLA exploitation attack combined with forged e-Sign JWT assertions on the Property Registry API.

7 Min MEAN TIME TO DETECT (MTTD)	15 Min MEAN TIME TO CONTAIN (MTTC)	20 Min ERADICATION & RECOVERY	0 Min SYSTEM DOWNTIME	1,240 EXFILTRATION CAPPED
--	--	-------------------------------------	--------------------------	---------------------------------

NIST SP 800-61 Incident Lifecycle Execution

- **Preparation:** Configured custom Elasticsearch/Kibana alert triggers for API rate surges and established automated patch deployment pipelines.
- **Detection & Analysis (T+00m to T+07m):** Attacker initiated automated queries at 120 req/sec. SIEM triggered alert ALERT-API-ANOMALY-092 at T+03m. Triage confirmed BOLA parameter tampering returning land records across different citizen IDs.
- **Containment (T+07m to T+15m):** Applied immediate Cloudflare WAF IP blocks, revoked compromised e-Sign middleware signing keys, and restricted microservice traffic via Kubernetes NetworkPolicy.
- **Eradication & Recovery (T+15m to T+37m):** Deployed API Gateway hot-patch enforcing ABAC (`request.auth.user_id == resource.owner_id`), mandated RS256 token verification, and performed rolling pod restarts with zero downtime.
- **Post-Incident Review (T+42m):** System normalized, forensic evidence locked, and vendor SLA communication gap noted for playbook refinement.

Key Technical Strengths Identified	Identified Operational Bottlenecks
• SIEM detection rules flagged anomaly within 180 seconds. • Rolling updates enabled hot-patching with zero downtime. • Pre-scripted WAF rate rules halted mass data scraping.	• Initial 5-minute delay coordinating key revocation with external e-Sign vendor. • Application error logs temporarily captured raw headers before pod isolation.

5. Emerging Cyber Trends & Long-Term Roadmap

Week 4 addressed long-term threat evolution over the 2026–2030 horizon. Rapid adoption of agentic AI and advances in quantum computing require transitioning AuraGov toward an adaptive, quantum-resistant Zero Trust posture.

Emerging Technology Threat Vectors

- 1. **AI-Driven API Logic Swarms:** Autonomous agentic AI models executing real-time parameter probing to exploit subtle access control logic gaps faster than signature-based WAFs can react.
- 2. **Cryptographic Sunset ("Harvest Now, Decrypt Later"):** Threat actors intercepting encrypted citizen telemetry today to decrypt using future quantum hardware, undermining classical RSA/ECC encryption.
- 3. **Decentralized Sovereign Identity (SSI & ZKP):** Replacing centralized identity honeypots with W3C Verifiable Credentials and Zero-Knowledge Proofs (ZKP) to prove eligibility without exposing raw PII.
- 4. **Autonomous Agentic SOAR:** Upgrading SIEM/SOAR platforms to execute automated container isolation and dynamic patch deployment in under 2 minutes.

Future Readiness Index (FRI) Assessment

To quantify AuraGov’s future resilience, we calculated the Future Readiness Index (FRI):

$$FRI = (\sigma_{PQC} \times \alpha_{ZT}) / (\delta_{AI} \times \tau_{Legacy})$$

Where σ_{PQC} is Post-Quantum Readiness, α_{ZT} is Zero Trust Coverage, δ_{AI} is AI Attack Susceptibility, and τ_{Legacy} is Legacy Ratio. Target index score is $FRI > 0.500$.

Evaluation Baseline	Calculated Index Score	Strategic Posture & Impact
Current Baseline (2026)	FRI = 0.007	High vulnerability to automated AI swarms and quantum key decay.
Strategic Target (2030)	FRI = 0.518	Sustained resilience through hybrid PQC, complete mTLS, and ZKP identity.

Strategic 4-Year Phased Implementation Roadmap (2026–2030)

Phase & Period	Core Technical Deliverables	Target Outcome Metrics
Phase 1 (Months 0–12)	• Deploy AI-driven WAF behavior analysis. • Implement automated PII log masking filters. • Conduct comprehensive PQC cryptographic asset audit.	0% unmasked PII leaks in logs; 100% API endpoints covered by AI rate limiting.
Phase 2 (Months 12–24)	• Enforce Istio service mesh mTLS across all Kubernetes pods. • Implement hybrid ML-KEM / ML-DSA Post-Quantum tokens. • Integrate continuous DAST into CI/CD pipelines.	100% internal mTLS coverage; Hybrid PQC token verification active on e-Sign gateways.
Phase 3 (Months 24–48)	• Deploy Self-Sovereign Identity (SSI) with ZKP integration. • Transition SOC to fully autonomous agentic SOAR playbooks. • Achieve full NIST SP 800-208 PQC compliance.	Mean Time to Contain (MTTC) < 2 minutes; Elimination of centralized PII honeypots.

6. Student Reflection & Internship Key Learnings

My experience in the **YUVA Cybersecurity Internship Program** has been transformative. Analyzing a complex e-governance infrastructure like AuraGov provided invaluable practical perspective on how technical vulnerabilities impact real-world public services and citizen privacy.

Key professional and technical capabilities developed include:

- **API Security Mastery:** Gained deep experience identifying BOLA logic gaps, implementing Attribute-Based Access Control (ABAC), and configuring secure JWT verification logic.
- **Practical Threat Modeling:** Applied frameworks like STRIDE and MITRE ATT&CK to quantitatively evaluate risks and map threats to concrete defense controls.
- **Incident Response Execution:** Experienced the fast-paced reality of threat triage, containment, hot-patching, and post-incident analysis under NIST SP 800-61 guidelines.
- **Forward Defense Planning:** Developed an appreciation for long-term cybersecurity architecture, including Post-Quantum Cryptography, Zero-Knowledge Proofs, and agentic SOC automation.

I want to express my sincere gratitude to the YUVA Internship Program mentors and advisors for their guidance throughout this program. This experience has solidified my dedication to pursuing a career in cybersecurity and digital infrastructure defense.

Submitted by: Deepika Jaiswal (Student ID: 2410030120)

Program: YUVA Cybersecurity Internship — Final Synthesis Report